

Documento de Negocio

Producto, mercado, modelo de negocio y go-to-market

1. Resumen ejecutivo

Las fintechs mexicanas de 20 a 200 empleados operan bases de datos PostgreSQL con datos sensibles de sus clientes sin saber con certeza qué tienen, quién puede acceder a ellos ni si su configuración cumple con LFPDPPP, CNBV o PCI-DSS. Cuando llega una auditoría regulatoria, el equipo de TI pasa días recopilando evidencia de forma manual, un proceso costoso, incompleto y repetible.

PgVault es una herramienta de auditoría de seguridad y cumplimiento para PostgreSQL. Se conecta en modo solo lectura, detecta datos sensibles (CURP, RFC, tarjetas, emails), audita privilegios y configuración insegura, y genera un reporte con score de seguridad y mapeo a regulación mexicana en minutos, no semanas.

El mercado objetivo son las más de 1,000 fintechs en operación en México. Las herramientas comparables (Satori, Cyral, Immuta, BigID) cuestan entre \$50,000 y \$200,000 USD anuales y no tienen soporte para regulación mexicana. PgVault opera con tres tiers: Starter (\$1,499 MXN/mes), Pro (\$2,499 MXN/mes) y Enterprise (custom), atacando el segmento SMB que nadie atiende.

El equipo está compuesto por 5 ingenieros con roles especializados en conexión, auditoría de configuración, detección de datos sensibles, reportes regulatorios y producto. El diferenciador central es el mapeo nativo a LFPDPPP y CNBV — algo que ningún competidor ofrece hoy.

2. Problema

2.1 Descripción del problema

Son las 11 pm del martes. La auditoría regulatoria de la CNBV llega el jueves. El equipo de TI lleva 2 días sin dormir revisando configuraciones, buscando evidencia.

Las fintechs mexicanas de 20 a 200 empleados manejan bases de datos PostgreSQL con datos personales y financieros de sus clientes. Están sujetas a LFPDPPP, disposiciones de CNBV y en muchos casos PCI-DSS. Sin embargo, sus equipos de TI - de 2 a 5 personas - enfrentan tres problemas simultáneos:

1. **No saben qué tienen.** 47 columnas con datos personales en 12 tablas, sin inventario. La respuesta típica es "más o menos", dependiendo de que alguien haya documentado el schema en algún momento.
2. **Saben pero no auditan.** La última revisión de privilegios fue hace 3 años. Los roles han crecido sin control desde entonces.
3. **Auditan manualmente.** Un consultor externo cuesta \$20,000 USD y su reporte caduca en 30 días.

El resultado: equipos de TI reactivos, auditorías costosas en tiempo y dinero, y riesgo regulatorio permanente que solo se hace visible cuando ya es un problema.

2.2 User persona principal

Atributo	Valor
Nombre y rol	Carla Méndez, CISO / Responsable de TI
Edad	35–42 años
Experiencia	8–12 años en TI, 2–4 años en el rol actual
Tamaño de empresa	Fintech mexicana, 50–150 empleados
Industria	Tecnología financiera — pagos, crédito digital, ahorro
Equipo de TI	2–4 personas, sin DBA dedicado
Día típico	4 horas/semana revisando logs manualmente — ella misma hace la auditoría.
Problemas principales	No sabe qué datos sensibles tiene en producción; recibe auditorías de CNBV y tarda días preparando evidencia; privilegios sin revisar desde hace años.

Carla Méndez es CISO de una fintech mexicana de 50 a 150 empleados. No tiene DBA dedicado -ella misma hace la auditoría. Dedicar 4 horas a la semana revisando logs manualmente. La última vez que revisaron los privilegios de su base de datos fue hace 3 años. Hoy paga \$15,000 dólares al año a un consultor externo para que le entregue un reporte que caduca en 30 días. Y si mañana hay una brecha de datos, la multa estimada de la CNBV es de \$500,000 pesos. Carla no tiene un problema de presupuesto - tiene un problema de visibilidad y de tiempo. PgVault le da en 10 minutos lo que hoy le toma semanas y \$15,000 dólares.

2.3 Frecuencia y severidad

Frecuencia: auditorías CNBV 1- 2 veces al año, reactivas. **Severidad:** multa CNBV estimada si hay breach: \$500,000 MXN — dato directo de la user persona de la presentación. **Costo estimado sin PgVault:** \$15,000 USD/año en consultoría externa, con reporte que caduca en 30 días.

Severidad: Una brecha de datos personales bajo LFPDPPP puede resultar en multas de hasta 320,000 días de salario mínimo (~\$17M MXN). Una auditoría de CNBV fallida puede derivar en sanciones operativas. El costo de preparar evidencia manualmente se estima en 3–5 días-hombre por evento, a un costo de \$500–2,000 USD por auditoría en tiempo del equipo.

Costo estimado sin PgVault: \$1,500–6,000 USD/año en tiempo de auditoría manual, sin contar el riesgo de multas regulatorias.

3. Investigación de usuarios

3.1 Resumen de entrevistas

Nombre / Rol del entrevistado	Empresa / Sector	Fecha	Duración
Maybel Noguera / DBA Senior	Telecomunicaciones	12/05/2026	15 min
Eduardo Pachecho / Consultor DBA	Consultoría de BD	12/05/2026	15 min
Eliu Vilchis / Consultor DBA	Consultoría de BD	13/05/2026	15 min

3.2 Preguntas hechas

1. ¿Cuál es tu rol actual y en qué tipo de empresa trabajas?
2. ¿Tienen bases de datos PostgreSQL en producción? ¿Cuántas, más o menos?
3. ¿Saben qué datos sensibles tienen almacenados en su base de datos? ¿Cómo lo saben?
4. ¿Han tenido alguna auditoría de seguridad o cumplimiento? ¿Qué proceso siguieron para prepararla?
5. ¿Tienen control sobre quién puede acceder a qué tablas o columnas en la base de datos?
6. Si tuvieran que demostrar hoy que su base de datos cumple con LFPDPPP o PCI-DSS, ¿cuánto tiempo les tomaría?
7. ¿Qué herramientas usan hoy para monitorear o auditar su base de datos?
8. ¿Qué tan fácil es saber si alguien tiene más privilegios de los que debería en la base de datos?
9. Si existiera una herramienta que se conecta en modo solo lectura a su PostgreSQL, detecta datos sensibles, revisa privilegios y genera un reporte con mapeo a regulación mexicana en minutos — ¿la usarían? ¿Qué les generaría desconfianza?
10. ¿Qué precio les parecería razonable por algo así? ¿Lo preferirían como suscripción mensual o pago único?

3.3 Aprendizajes principales

Aprendizaje 1: La visibilidad es reactiva, no proactiva.

Los 3 entrevistados sólo saben qué datos sensibles tienen cuando alguien externo lo solicita (auditoría, requerimiento de seguridad). No existe revisión sistemática y proactiva.

Aprendizaje 2: El proceso de auditoría es completamente manual.

Maybel Noguera describió el proceso como "nos piden evidencias y nosotros recopilamos la información y se la enviamos"- sin herramienta de apoyo, dependiendo del conocimiento individual del equipo.

Aprendizaje 3: La desconfianza inicial es la principal barrera de adopción.

Eduardo Pacheco señaló que la decisión de adoptar una herramienta nueva involucra múltiples áreas (DBA, seguridad, comercial). Maybel indicó que "de primera instancia no la usaría hasta validar". Esto refuerza la necesidad de un modelo open source y verificable.

Aprendizaje 4: El precio no es la objeción principal.

Ningún entrevistado mencionó el precio como barrera. Eliu señaló que la confianza y la capacidad de validar lo que hace la herramienta es lo más importante.

Aprendizaje 5: Hay preferencia por pago único o descuento en anual.

Maybel y Eliu señalaron que preferirían pago único a menor costo que mensualidad acumulada - consistente con el comportamiento de compra de equipos de TI en empresas medianas mexicanas.

4. Solución

Carla llega un lunes por la mañana con un correo de la CNBV: tienen 48 horas para demostrar cumplimiento. Sin PgVault, llama a su equipo, pasan el día revisando logs manualmente y preparando un Excel con usuarios y permisos. Con PgVault, ejecuta un análisis en 10 minutos y obtiene un reporte PDF con score de seguridad, hallazgos priorizados y mapeo exacto a los artículos de LFPDPPP y CNBV que debe cumplir. Envía el reporte esa misma tarde.

4.1 Funcionalidades core

Feature	Beneficio para el usuario
Detección de datos sensibles por nombre de columna	Sabe inmediatamente qué columnas contienen CURP, RFC, emails, tarjetas o teléfonos
Detección por contenido con muestreo estadístico	Encuentra datos sensibles, aunque la columna tenga un nombre genérico
Score de confianza por hallazgo	Diferencia hallazgos certeros de posibles falsos positivos
Auditoría de privilegios y roles	Identifica usuarios con SUPERUSER innecesario y accesos excesivos
Detección de funciones SECURITY DEFINER	Encuentra configuraciones inseguras que elevan privilegios automáticamente
Reporte PDF con score de seguridad	Entrega evidencia lista para presentar en auditorías
Mapeo a LFPDPPP, PCI-DSS y CNBV	Vincula cada hallazgo al artículo regulatorio específico que incumple
Recomendaciones con SQL exacto	El equipo sabe exactamente cómo corregir cada hallazgo

5. Análisis competitivo

5.1 Tabla comparativa

Característica	Satori	Cyral	INMUTA	BigID	PgVault
Precio	\$50,000–\$150,000 USD/año	\$80,000–\$200,000 USD/año	\$100,000+ USD/año	\$80,000–\$200,000 USD/año	~\$1,499–\$2,499 USD/año
On-premise	Parcial	No	Parcial	No	Si
Sin agente	No	Si	No	No	
Soporte en español	No	No	No	No	Si
Regulación mexicana (LFPDPPP/CNBV)	No	No	No	No	Si
Setup	Semanas	Semanas	Meses	Meses	Inmediato
Segmento	Enterprise	Enterprise	Enterprise	Enterprise	LATAM SMB
Modo solo lectura verificable	No	No	No	No	Si

5.2 Análisis honesto

Satori:

- Mejor que nosotros en: cobertura multi-base de datos, integraciones enterprise, soporte 24/7.
- Nosotros mejores en: precio (50x menor), regulación mexicana, especialización en PostgreSQL, on-premise.

Cyral (ahora Varonis):

- Mejor que nosotros en: integración con ecosistema Varonis, monitoreo de actividad en tiempo real.
- Nosotros mejores en: precio, independencia de plataforma, regulación local, foco en PostgreSQL.

Immuta:

- Mejor que nosotros en: governance de datos a escala enterprise, políticas de acceso dinámicas.
- Nosotros mejores en: precio (33x menor), simplicidad de instalación, regulación mexicana.

BigID:

- Mejor que nosotros en: discovery en múltiples fuentes de datos, clasificación avanzada con ML.
- Nosotros mejores en: precio (hasta 100x menor), especialización, on-premise, regulación local.

5.3 Espacio en blanco

Nuestro nicho: Fintechs y SaaS B2B mexicanas de 20–200 empleados con PostgreSQL en producción y obligaciones regulatorias LFPDPPP/CNBV.

Los competidores no atienden bien este nicho porque: Sus precios son inaccesibles para equipos de menos de 200 personas, no tienen mapeo a regulación mexicana, no tienen soporte en español y requieren implementaciones complejas que superan la capacidad de equipos de TI pequeños.

Nosotros podemos servirlo bien porque: Somos open source, sin agente, con instalación en un comando Docker, precio accesible, reporte en español y mapeo nativo a LFPDPPP y CNBV.

6. Modelo de negocio

6.1 Tipo de modelo de revenue

- ☒ Suscripción mensual / anual
- ☐ Por uso (pago por análisis ejecutado, etc.)
- ☐ Por seat (por usuario activo)
- ☐ Por instancia (por BD monitoreada)
- ☐ Freemium con tier pago
- ☐ Otro: _____

6.2 Tiers de pricing

Tier	Precio/mes	Comprador objetivo	Qué incluye
Starter	\$1,499 USD	Fintech de 20–50 empleados, 1 BD	Módulo de configuración, descubrimiento PII por nombre de columna, reporte ejecutivo PDF, score de seguridad.
Pro	\$2,499 USD	Fintech de 50–150 empleados, hasta 5 BDs	Todo Starter + PII por contenido (sampling), reporte técnico completo, historial de scans 12 meses, mapeo regulatorio extendido.
Enterprise	\$USD/costume	Empresa de 150+ empleados.	Todo Pro + on-premise/air-gapped, SLA 99.9%, onboarding dedicado, integración con SIEM.

6.3 Justificación del precio

El tier Starter de \$1,499 MXN/mes (~\$75 USD) representa menos del 1% del costo de una consultoría externa anual (\$15,000 USD). Frente a Satori (~\$50,000–\$150,000 USD/año), PgVault es entre 40 y 125 veces más barato.

Podemos ofrecer este precio porque somos open source, sin infraestructura propia de datos del cliente, sin equipo de ventas enterprise y sin soporte global 24/7. El cliente corre PgVault en su servidor - nuestro costo marginal por cliente nuevo es cercano a cero.

7. Tamaño de mercado

TAM / SAM / SOM

TAM (Total Addressable Market): el universo total. Citen fuentes (Gartner, IDC, etc.).

SAM (Serviceable Addressable Market): la porción que pueden atender realísticamente.

SOM (Serviceable Obtainable Market): lo que realmente capturarían en 3-5 años.

7.1 TAM

Definición: Todas las empresas en LATAM que usan PostgreSQL y están sujetas a regulación de datos.

Cifra: \$6.3B USD (mercado global de database security accesible para soluciones especializadas en compliance regulatorio).

7.2 SAM

Definición: Fintechs y SaaS B2B en México con PostgreSQL en producción y obligaciones regulatorias LFPDPPP/CNBV.

Cifra: \$180M USD - fintechs latinoamericanas con obligación regulatoria y stack PostgreSQL en producción.

7.3 SOM

Definición: Lo que PgVault puede capturar realísticamente en 3–5 años.

Cifra: \$3.6M USD - penetración estimada del 2% del SAM en 5 años, comenzando con México y expandiendo a Colombia, Chile y Argentina.

7.4 Tendencias relevantes

Tendencia 1 - Crecimiento de PostgreSQL en LATAM: PostgreSQL es el motor de BD de mayor crecimiento en startups latinoamericanas. Su adopción en fintechs creció 40% entre 2022 y 2024 (DB-Engines ranking).

Tendencia 2 - Endurecimiento regulatorio en México: La CNBV aumentó el número de disposiciones de seguridad de la información para ITFs en 2023. El INAI incrementó sus multas a empresas que no acreditan medidas técnicas de protección.

Tendencia 3 - Consolidación del mercado enterprise: La adquisición de Cyral por Varonis en marzo 2025 confirma que el mercado enterprise se consolida hacia plataformas grandes, dejando el segmento SMB sin opciones especializadas accesibles.

Gartner. (2024). Forecast: Information Security and Risk Management, Worldwide, 2022-2028. <https://www.gartner.com>

DB-Engines. (2024). Knowledge Base of Relational Database Management Systems: PostgreSQL Growth Ranking. <https://db-engines.com/en/ranking/postgresql>

Crunchbase. (2025). Fintech Mexico Ecosystem Report 2024-2025. <https://www.crunchbase.com>

8. Go-to-market

8.1 Primeros 10 clientes

Objetivo: 10 clientes pagados en los primeros 12 meses post-lanzamiento.

Plan paso a paso:

1. Mes 1–2 - Evento Fintech México 2026: 250 fintechs presentes. Agendar 30 demos en el evento. Cerrar 5 pilotos gratuitos a 90 días.
2. Mes 2–3 - Convertir pilotos: De 5 pilotos gratuitos, convertir 3 a clientes Pro. Generar caso de éxito documentado → referidos.
3. Mes 3–6 - Canal indirecto: Alianza con 2–3 consultoras de compliance fintech en México. Comisión del 20% el primer año. Acceso a cartera de clientes existente.
4. Mes 6–12 - Contenido y comunidad: Blog técnico en español sobre seguridad en PostgreSQL. Newsletter para CISOs. Presencia en OWASP México.

8.2 Estrategia de growth (después de los 10)

Canal 1 - Contenido técnico SEO: Artículos sobre LFPDPPP + PostgreSQL posicionan PgVault en búsquedas orgánicas de equipos de TI buscando cumplimiento regulatorio.

Canal 2 - Partnerships con consultoras: Acuerdos con consultoras de cumplimiento regulatorio en México que recomienden PgVault a sus clientes como herramienta de evidencia.

Canal 3 - Expansión LATAM: Replicar el modelo en Colombia (SFC), Chile (CMF) y Argentina (BCRA) — regulaciones financieras similares con el mismo stack tecnológico.

9. Diferenciador defendible

Nuestro diferenciador es: Mapeo nativo a regulación mexicana (LFPDPPP y CNBV) con artículos específicos por hallazgo, en español, para PostgreSQL, a precio SMB.

Es defendible en el tiempo porque: La regulación mexicana es un conocimiento especializado que requiere inversión en investigación legal y actualización continua. Un competidor enterprise que quisiera entrar a este nicho tendría que localizar su producto, traducir su documentación, entrenar a su equipo de ventas en el mercado mexicano y bajar radicalmente su precio — todo esto para un segmento que consideran pequeño. No es rentable para ellos.

Ejemplos concretos de cómo se manifiesta:

- El reporte PDF cita el artículo exacto de LFPDPPP que cada hallazgo incumple
- Las recomendaciones están redactadas en el contexto de la regulación mexicana, no adaptadas de GDPR
- El soporte y la documentación están en español desde el día 1

10. Por qué nuestro equipo

Somos 5 ingenieros especializados, cada uno responsable de una capa crítica del sistema. Nuestra ventaja no es solo técnica — es la combinación de profundidad en PostgreSQL,

entendimiento del contexto regulatorio mexicano y capacidad de ejecutar un MVP completo en 3 semanas.

Diego Vega construyó la capa de conexión y orquestación. Dowshell Smith implementó los checks de auditoría de configuración. Daniela Borquez diseñó el motor de detección de datos sensibles. Mariajose Rito construyó el sistema de reportes y el mapeo regulatorio. Cesar Mendez validó el mercado con entrevistas reales y estructuró la estrategia de negocio.

11. Roadmap a 12 meses

Trimestre	Producto	Negocio	Operativo
Q3 2026	Soporte MySQL/MariaDB, alertas programadas, dashboard web	10 clientes pagados, 3 testimoniales publicados	Documentación completa en español
Q4 2026	Integración con Slack/Teams para alertas, API pública	Expansion a Colombia y Chile, partnerships con 2 consultoras	Ingresos recurrentes mensuales
Q1 2027	Motor de remediación asistida (aplica SQL con aprobación), soporte multi-BD en un reporte	50 clientes activos en LATAM	Equipo de 2 personas de soporte
Q2 2027	Módulo de cumplimiento continuo (escaneo automático semanal), integración CI/CD	Lanzamiento en Argentina, \$15,000 USD ARR	Evaluación de ronda pre-seed

12. Ask

Si esto fuera un pitch real de inversión, pediríamos:

- **\$50,000 USD en pre-seed** para cubrir 12 meses de operación, asistencia a 3 eventos de fintechs en LATAM y desarrollo de los features Q3 2026.
- **3 mentores con red en fintechs mexicanas** que puedan abrir puertas a los primeros 10 clientes pagados.
- **2 fintechs piloto:** dispuestas a usar PgVault en producción a cambio de influir en el roadmap durante los primeros 90 días.

— Fin del documento —